Les Fondamentaux des Réseaux pour la Cybersécurité

Guide d'étude complet : tout ce que vous devez maîtriser en réseautique avant (et pendant) votre entrée dans le domaine de la cybersécurité.

Sommaire du programme

1. Pourquoi le réseau est le socle de la cybersécurité
2. Le modèle OSI et le modèle TCP/IP
3. Adressage IP, notation CIDR et subnetting
4. Les protocoles essentiels (TCP, UDP, DNS, DHCP, ARP, ICMP...)
5. Les ports et services incontournables
6. Équipements réseau : routeur, switch, pare-feu, point d'accès
7. Routage, NAT et VPN
8. Réseaux sans fil (Wi-Fi)
9. Sécurité des réseaux : concepts et bonnes pratiques
10. Outils à apprendre : Wireshark, Nmap, etc.
11. Section 12 : Linux et ligne de commande
12. Feuille de route d'apprentissage (3 à 6 mois)
13. Ressources gratuites recommandées

Document généré pour l'étude personnelle - bonne lecture !

1. Pourquoi le réseau est le socle de la cybersécurité

La cybersécurité consiste à protéger des systèmes, des données et des communications. Or 95% des communications passent par des réseaux. Un pirate comme un défenseur doivent comprendre exactement comment les données circulent : qui parle à qui, sous quel protocole, sur quel port, et où se trouvent les points faibles.

Concrètement, sans bases réseau solides, vous ne pourrez ni :

- comprendre comment une attaque arrive jusqu'à la cible (reconnaissance, détournement de sessions, etc.) ;
- analyser un trafic suspect avec un outil comme Wireshark ;
- configurer et comprendre un pare-feu ou un système de détection d'intrusion (IDS/IPS) ;
- réussir un CTF (Capture The Flag) ou des labs comme TryHackMe / Hack The Box ;
- passer des certifications comme Network+, Security+, CCNA, CEH ou OSCP.

Astuce : Les recruteurs en cybersécurité testent presque toujours les bases réseau à l'entretien : modèle OSI, ports, DNS, subnetting. C'est LE prérequis n°1 du domaine.

2. Le modèle OSI et le modèle TCP/IP

2.1 Le modèle OSI (7 couches)

Le modèle OSI est une référence théorique qui découpe les communications réseau en 7 couches. MÉMORISEZ-LE PAR COEUR : c'est le vocabulaire commun de toute la cybersécurité.

N°	Couche	Rôle	Exemples
7	Application	Interface avec l'utilisateur et les logiciels	HTTP, DNS, SMTP
6	Présentation	Format, encodage, chiffrement	TLS/SSL, JPEG
5	Session	Ouverture et gestion des sessions	RPC, NetBIOS
4	Transport	Connexion de bout en bout, ports, fiabilité	TCP, UDP
3	Réseau	Adressage logique (IP) et routage	IP, ICMP, ARP
2	Liaison de données	Adressage physique (MAC), trames	Ethernet, Wi-Fi
1	Physique	Signaux, câbles, ondes radio	Câble RJ45, fibre

Astuce pour retenir l'ordre (de 7 à 1) : « All People Seem To Need Data Processing ».

2.2 Le modèle TCP/IP (4 couches)

Le modèle TCP/IP est celui utilisé réellement par Internet. Il regroupe les couches OSI en 4 couches :

- **Application (OSI 5-6-7)**
  : HTTP, HTTPS, DNS, SMTP, SSH, FTP
- **Transport (OSI 4)**
  : TCP et UDP, avec les numéros de ports
- **Internet (OSI 3)**
  : IP, ICMP, routage
- **Accès réseau (OSI 1-2)**
  : Ethernet, Wi-Fi, cartes réseau

Pourquoi c'est crucial en cybersécurité : on parle d'attaques « couche 3 » (spoofing, sniffing), « couche 4 » (scan de ports, SYN flood), « couche 7 » (injection SQL, DDoS applicatif). Savoir localiser une attaque sur une couche aide à choisir la défense adaptée.

3. Adressage IP, CIDR et subnetting

3.1 Adresse IPv4

Une adresse IPv4 est un nombre de 32 bits, noté en 4 octets : par exemple 192.168.1.10. Elle contient deux parties : la partie réseau (commune à toutes les machines du même réseau) et la partie hôte (identifiant de la machine).

Type	Plage	Usage
Publique	Attribuée par un fournisseur d'accès	Visible sur Internet
Privée	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16	Réseaux internes (non routables sur Internet)
Loopback	127.0.0.1 (/8)	La machine elle-même (« localhost »)
APIPA	169.254.0.0/16	Auto-attribution quand le DHCP échoue

3.2 Masque et notation CIDR

Le masque de sous-réseau indique où s'arrête la partie réseau. La notation CIDR l'abrège : /24 signifie 24 bits de partie réseau (masque 255.255.255.0), ce qui laisse 256 adresses (254 utilisables).

CIDR	Masque	Nombre d'adresses	Hôtes utilisables
/24	255.255.255.0	256	254
/16	255.255.0.0	65 536	65 534
/8	255.0.0.0	16 777 216	16 777 214
/30	255.255.255.252	4	2

3.3 Le subnetting

Le subnetting consiste à découper un grand réseau en plusieurs sous-réseaux plus petits. C'est un grand classique des examens (Network+, CCNA) et indispensable pour indexer un réseau, cloisonner une DMZ, ou analyser des logs.

Méthode rapide : dans 192.168.1.0/26, le /26 réserve 26 bits pour le réseau. Les 6 bits restants donnent 64 adresses par sous-réseau (192.168.1.0-63, 192.168.1.64-127, etc.). Dans chaque sous-réseau, la première adresse est l'adresse de réseau et la dernière est la diffusion (broadcast).

Astuce : Entraînez-vous au subnetting tous les jours pendant 2 semaines : des sites comme subnettingpractice.com ou la vidéo « Subnetting in 10 minutes » vous rendent très rapide. C'est quasi systématique en examen.

3.4 IPv6 (les bases)

- Adresses de 128 bits, notées en hexadécimal : 2001:0db8::1.
- Plus de NAT : chaque machine peut avoir une adresse globale unique.
- À connaître au niveau conceptuel pour la cybersécurité (scanning IPv6, configurations).

4. Les protocoles essentiels

4.1 TCP vs UDP

Caractéristique	TCP	UDP
Connexion	Établie (3-way handshake SYN / SYN-ACK / ACK)	Sans connexion
Fiabilité	Accusés de réception, retransmission	Aucune garantie
Vitesse	Plus lente	Très rapide
Usages	Web, email, transfert de fichiers	DNS, jeux vidéo, streaming, VoIP

En cybersécurité : le SYN flood (attaque DoS) exploite le handshake TCP ; le scan de ports Nmap s'appuie sur TCP et UDP ; les rebonds de connexions partent souvent de TCP/443.

4.2 DNS (port 53)

Le DNS traduit les noms de domaine (exemple.com) en adresses IP. C'est un protocole vital et aussi une cible d'attaque majeure :

- Résolution récursive : le résolveur interroge racine, .com, puis le serveur du domaine.
- Attaques connues : DNS poisoning / spoofing, tunneling DNS (exfiltration de données), DNS hijacking, amplification DNS pour du DDoS.
- En défense : DNSSEC, filtrage DNS (Ex : Quad9, 1.1.1.3), surveiller les requêtes anormales.

4.3 DHCP (ports 67/68)

Le DHCP attribue automatiquement IP, masque, passerelle et DNS aux machines. À connaître : le rogue DHCP server (attaque par usurpation de DHCP) qui permet à un attaquant de détourner le trafic des victimes (Man-in-the-Middle).

4.4 ARP

ARP fait le lien entre adresse IP et adresse MAC sur un réseau local. Il est intrinsèquement non sécurisé : l'attaque ARP poisoning / ARP spoofing permet une interception (MITM). Outils de démo et d'analyse : arp, arp-scan, Ettercap, arpspoof.

4.5 ICMP

ICMP sert aux diagnostics et messages d'erreur. Les commandes ping et traceroute s'appuient dessus. Côté sécurité : ping sweep pour cartographier un réseau, attaque « ping de la mort », ventilation et filtrage ICMP dans un pare-feu, tunnel ICMP dans certains outils.

4.6 HTTP / HTTPS (ports 80 / 443)

Le web repose sur HTTP(S). Tout analyste SOC doit connaître :

- Les méthodes : GET, POST, PUT, DELETE, HEAD ; les codes de réponse (200, 301, 403, 404, 500).
- HTTPS chiffre les échanges grâce au TLS : la mise en relation repose sur des certificats.

- Attaques classiques : XSS, injection SQL/RCE, brute force de formulaires, redirection abusive, falsification de certificats.
- En défense : HSTS, en-têtes de sécurité (CSP), WAF, TLS 1.2+/1.3.

4.7 Autres protocoles à connaître (vue d'ensemble)

Protocole	Port	Rôle	Note sécurité
SSH	22	Administration distante chiffrée	Brute force : limiter, clés, fail2ban
SMTP	25/587	Envoi d'emails	Phishing, usurpation (SPF, DKIM, DMARC)
POP3/IMAP	110/143	Lecture d'emails	Chiffrement (993/995)
FTP	21	Transfert de fichiers (non chiffré)	Remplacer par SFTP/FTPS
SMB	445	Partage Windows	EternalBlue, pass-the-hash
RDP	3389	Remote Desktop	Exposition : brute force, BlueKeep
Telnet	23	Terminal distant en clair	À proscrire, remplacer par SSH
SNMP	161	Supervision réseau	Version 3 seulement (authentification)
NTP	123	Synchronisation de l'heure	Attaques par amplification
Kerberos	88	Authentification Active Directory	Kerberoasting, Golden Ticket

Astuce : Ce tableau de ports est LE REFLEXE (a retenir par coeur) de tout professionnel sécurité. Apprenez-en au moins une dizaine : 20/21, 22, 23, 25, 53, 67/68, 80, 110, 123, 135, 139/445, 389, 443, 445, 3389.

5. Ports et services : les incontournables

Un port est un numéro (0-65535) qui identifie le service/applicatif sur une machine. On distingue les ports bien connus (0-1023), enregistrés (1024-49151) et dynamiques/éphémères (49152-65535). Le duo IP:port identifie précisément une conversation.

À connaître absolument pour les CTF, Nmap et les certifications :

- 20/21 FTP - 22 SSH - 23 Telnet - 25 SMTP - 53 DNS - 67/68 DHCP
- 80 HTTP - 110 POP3 - 123 NTP - 137-139 NetBIOS - 143 IMAP
- 161 SNMP - 389 LDAP - 443 HTTPS - 445 SMB - 636 LDAPS
- 1433/3306 SQL Server/MySQL - 3389 RDP - 5060/5061 SIP (VoIP)

6. Équipements réseau

Switch

Centralise les machines d'un réseau local et achemine les trames selon les adresses MAC (table CAM). Attaques : MAC flooding, spoofing MAC, ARP poisoning. Défenses : port security, réseaux VLAN, DHCP snooping.

Routeur

Routage entre différents réseaux/IP. Décisions basées sur la table de routage et le saut suivant. En cybersécurité : ACL (listes de contrôle d'accès) au niveau du routeur, protection de la table de routage (BGP hijacking sur Internet).

Pare-feu (Firewall)

Filtre le trafic selon des règles (IP, port, protocole, direction). Types : filtrage de paquets, inspection d'états (stateful), proxy, NGFW (pare-feu nouvelle génération). Selon la position : pare-feu périmétrique, interne, basé sur l'hôte (Windows Defender Firewall, iptables).

IDS / IPS

IDS (détection, alerte) et IPS (blocage automatique) analysent les paquets à la recherche de signatures ou anomalies. Outils de référence : Snort, Suricata, Zeek. Un analyste SOC passe une grande partie de son temps à trier les alertes de ces systèmes.

Points d'accès Wi-Fi et VLAN

Le point d'accès (AP) rayonne le Wi-Fi. Les VLAN découpent logiquement un switch en réseaux indépendants : séparer les autorisations (production, invités, DMZ, IOT). MitM possible si les configurations sont faibles (VLAN hopping).

Autres équipements

- Proxy : intermédiaire pour le web (filtrage, mise en cache, anonymat).
- VPN concentrator : terminaison des tunnels chiffrés des télétravailleurs.
- Load balancer : répartition de charge devant plusieurs serveurs.
- Sandbox, SOAR, SIEM (plateforme d'agrégation des journaux : Splunk, Sentinel, Wazuh).

7. Routage, NAT, VPN

Routage

- Statique : configuré à la main. Dynamique : appris (RIP, OSPF, BGP).
- Passerelle par défaut : la porte de sortie vers les autres réseaux.
- Traceroute / tracepath montre le chemin parcouru (les routeurs traversés).

NAT / PAT

Le NAT (Network Address Translation) permet à un réseau privé d'utiliser une seule adresse publique. Le PAT traduit les ports pour partager une même IP entre des dizaines de machines. Côté sécurité : le NAT masque la topologie interne, mais une mauvaise configuration (port forwarding excessif) expose des services internes.

VPN

Un VPN crée un tunnel chiffré au-dessus d'un réseau non fiable (Internet) : VPN site-à-site entre entreprises, VPN client pour le télétravail. Protocoles : IPsec, OpenVPN, WireGuard. Un VPN protège le transport, pas la machine elle-même : ne confondez pas avec un antivirus.

8. Réseaux sans fil (Wi-Fi)

Norme	Fréquence	Vitesse max théorique
802.11b	2,4 GHz	11 Mbps
802.11a/g	5/2,4 GHz	54 Mbps
802.11n (Wi-Fi 4)	2,4/5 GHz	600 Mbps
802.11ac (Wi-Fi 5)	5 GHz	3,5 Gbps
802.11ax (Wi-Fi 6/6E)	2,4/5/6 GHz	~10 Gbps

Sécurité Wi-Fi à connaître absolument :

- WEP (cassé depuis longtemps) < WPA < WPA2 < WPA3 (à privilégier).
- WPA2-Enterprise (802.1X) pour l'authentification individuelle par certificat/rayon.
- Attaques typiques : capture du 4-way handshake + dictionnaire (aircrack-ng), Evil Twin/fake AP, déauth des clients, KRACK historique, fragmentation.
- Défenses : WPA3, portails captifs robustes, isolation des clients, supervision RF (WIDS/WIPS), segmentation des invités.

9. Sécurité des réseaux : les grands concepts

9.1 La triade CIA

Toute la cybersécurité s'articule autour de 3 objectifs : Confidentialité (rien aux regards non autorisés), Intégrité (rien d'altéré), Disponibilité (le service reste accessible). Chaque attaque et chaque défense se rapporte à au moins un de ces 3 piliers.

9.2 Les familles d'attaques réseau

Famille	Exemples	Défense typique
Écoute (sniffing)	Wireshark sur un port miroir, ARP poisoning	Chiffrement (TLS/SSH), ports protégés
Usurpation (spoofing)	ARP, DHCP, DNS usurpés, IP spoofing	DHCP snooping, DNSSEC, inscriptions dynamiques ARP
Interception (MITM)	Evil Twin, rogue AP, proxy caché	802.1X, certificats, détection WIDS
Déni de service (DoS/DDoS)	SYN flood, amplification DNS, volumnétrie	Rate limiting, anti-DDoS, CDN
Balayage et reconnaissance	Nmap, ping sweep, scan de ports	Segmentation, honeypots, détection IDS
Mot de passe	Brute force, dictionnaire	Longueur, MFA, fail2ban, verrouillage
Exploitation de services	EternalBlue (SMB), RDP	Mises à jour, moindre surface, patchs

9.3 Mécanismes de défense

- Segmentation : VLAN, DMZ, zones sensitive/clairement séparées.
- Principe du moindre privilège (least privilege).
- Chiffrement de bout en bout (TLS 1.3, SSH), PKI et gestion de certificats.
- Détection : SIEM pour centraliser des logs, IDS/IPS, NetFlow.
- Réponse : playbook d'incident, journalisation, sauvegardes testées (3-2-1).
- Zero Trust : « never trust, always verify », authentification forte permanente (MFA).

Astuce : Un principe clé : la défense en profondeur. On empile des protections (pare-feu, segmentation, MFA, chiffrement, supervision) plutôt que de compter sur une seule solution.

10. Les outils à maîtriser

Outil	Rôle	Pourquoi l'apprendre
Wireshark	Analyseur de paquets (sniffer)	Indispensable pour l'analyse de trafic en SOC
Nmap	Scanner de ports et de services	Base du pentest et de l'inventaire
tcpdump	Capture en ligne de commande	Indispensable sur serveurs Linux
ping / traceroute	Diagnostics	Premiers réflexes de tout technicien
netstat / ss	Connexions et ports ouverts	Analyse d'un poste compromis
dig / nslookup	Interrogations DNS	Analyse de phishing et résolution
iptables/nftables	Pare-feu Linux	Compréhension du filtrage sous Linux
Nessus / OpenVAS	Scanner de vulnérabilités	Gestion des vulnérabilités
Metasploit	Cadre d'exploitation (pentest)	LAB et certifications pentest
Burp Suite	Proxy d'attaque applicative web	Essentiel pour le web en pentest
aircrack-ng	Suite d'audit Wi-Fi	Compréhension des attaques sans fil
Zeek / Snort / Suricata	Détection IDS/NIDS	Compétences centrales du SOC

Astuce : Wireshark et Nmap sont les deux outils à apprendre en premier : ils font passer votre compréhension du réseau du niveau théorique au niveau pratique.

11. Linux et la ligne de commande

Le monde de la cybersécurité est un monde Linux (serveurs, Kali Linux, outils, serveurs web). Bases à posséder :

- Navigation : pwd, ls, cd, cp, mv, rm, mkdir ; permissions (chmod, chown, sudo).
- Fichiers et textes : cat, less, head, tail, grep, find, wc, cut, sort, uniq.
- Réseau : ip a, ip r, ip neigh (ARP), ss/netstat, dig, curl, wget, tcpdump, nmap, ping.
- Processus : ps, top, kill, systemctl (services), crontab (planification).
- Users & logs : /etc/passwd, /etc/shadow, last, lastb, /var/log/auth.log, journalctl.
- Scripts : bash et un peu de Python + PowerShell pour Windows.

Installez VirtualBox : un VM Kali Linux (attaque) + un VM Metasploitable ou une VM Ubuntu (cible) pour vous entraîner sans risque juridique.

12. Feuille de route d'apprentissage (3-6 mois)

Étape 1 : Bases réseau (4-6 semaines)

- OSI/TCP-IP, adressage IP, subnetting, protocoles, ports, équipements.
- Installations pratiques : Wireshark sur votre propre trafic, ping/traceroute/dig, lecture d'un échange DNS et d'un handshake TCP.
- Simulateur gratuit : Cisco Packet Tracer ou GNS3 pour créer des réseaux virtuels.

Étape 2 : Bases système et Linux (3-4 semaines, en parallèle)

- Ligne de commande Linux, permissions, services, logs, réseau sous Linux.
- Scripting simple bash + notions de Python.

Étape 3 : Sécurité appliquée (4-6 semaines)

- Nmap : scénarios de scan (découverte d'hôtes, versions de services, scripts).
- Wireshark : reconnaissance FTP, HTTP, ARP, DNS malveillants dans des captures PCAP.
- Labs guidés : TryHackMe (Pre-Security, Network Fundamentals, Intro to Cyber Security).

Étape 4 : Aller plus loin (la suite)

- Certification d'entrée : CompTIA Network+ puis Security+ (ou CCNA si vous visez le réseau).
- Puis spécialisation : SOC analyste (Blue team), pentest (Red team), Cloud, GRC, forensique.
- Profitez des CTF (CTFtime), Hack The Box, PortSwigger Academy.

Règle d'or : 50% théorie, 50% pratique. Après chaque notion, testez-la : ouvrez Wireshark, lancez Nmap, capturez votre propre trafic.

13. Ressources gratuites recommandées

Ressource	Type	Utilité
TryHackMe - parcours Pre-Security / Intro to Cyber Security	Plateforme (partie gratuite)	Learning path guidé idéal
Cisco Packet Tracer / Cisco NetAcad	Simulateur + cours gratuits	Pratique réseau sans matériel
Professor Messer (YouTube)	Cours vidéo Network+/Security+	Préparation aux certifications
OverTheWire - Bandit	Jeux d'apprentissage SSH/Linux	Ligne de commande par la pratique
PortSwigger Web Security Academy	LABS web gratuits	HTTP/HTTPS, vulnérabilités web
Wireshark + exercices PCAP (malware-traffic-analysis.net)	Analyse de captures	Compétence n°1 du SOC
OpenClassrooms / Coursera (audits gratuits)	Cours structurés	Bases et certifications d'entrée

Conclusion

Le réseau est à la cybersécurité ce que l'anatomie est à la médecine : impossible de soigner sans connaître la structure. Maîtrisez le modèle OSI, l'adressage IP, les protocoles et les ports, puis apprenez à OBSERVER un vrai trafic avec Wireshark et à CARTOGRAPHIER un réseau avec Nmap. Avec ces fondations, chaque concept de cybersécurité - pare-feu, IDS, VPN, attaques - deviendra évident. Bon courage dans votre parcours !